

PROFILE SUMMARY

- Senior DevSecOps Engineer with 7 years of experience operating cloud-native DevSecOps environments across container-security SaaS, incident-response SaaS, and developer-tooling scaleups, specializing in CI/CD security gates, IaC and container scanning, and supply-chain hardening.
- Solid technical background across CI/CD pipelines (GitHub Actions, ArgoCD), AppSec scanning (Semgrep, Snyk), IaC scanning (Checkov), container security (Trivy), secrets management (HashiCorp Vault, GitGuardian), policy-as-code (OPA), supply-chain security (Sigstore Cosign), and languages (Python, Go) with strong fundamentals in shift-left scanning, automated guardrails, and developer-friendly remediation paths.
- Deep expertise in shift-left scanning gates, paved-road golden pipelines, policy-as-code enforcement, and SLSA-aligned supply-chain controls, leveraging methodologies such as risk-based scanner tuning and secure-default templates and security champions to drive fast, safe, and developer-friendly delivery.
- Engaged collaborator working cross-functionally with Engineering, SRE, Platform, and Security teams in security-as-a-product environments, contributing to RFC reviews, threat-modeling sessions, and post-incident retrospectives with a developer-first, ownership-first mindset.
- Emerging leader who shares technical excellence and fosters a culture of developer-experience obsession and signal-over-noise discipline through paved-road authoring and security office hours, while leading DevSecOps guild and security-champions sessions and authoring widely adopted scanning-pipeline and policy-as-code templates.

TECHNICAL SKILLS

CI/CD & Delivery:	GitHub Actions (composite actions, reusable workflows), GitLab CI, Jenkins, CircleCI, ArgoCD, Flux, security gates
AppSec Scanning (SAST/DAST/SCA):	Semgrep, SonarQube, Checkmarx, OWASP ZAP, Burp Suite Enterprise, Snyk, Dependabot, Mend, secure code review
IaC Security:	Checkov, tfsec, KICS, Terrascan across Terraform, CloudFormation, Bicep, Pulumi, Helm, and Kubernetes manifests
Container & Kubernetes Security:	Trivy, Grype, Snyk Container, OPA Gatekeeper, Kyverno admission policies, Falco runtime, distroless / minimal base images
Secrets Management & Detection:	HashiCorp Vault, AWS Secrets Manager, Doppler, 1Password Secrets Automation, GitGuardian, TruffleHog, Gitleaks
Policy as Code & Guardrails:	OPA / Rego, Kyverno, Conftest, HashiCorp Sentinel, admission control, automated policy-violation reporting
Supply Chain & Cloud Security:	SBOMs (Syft, CycloneDX, SPDX), Sigstore Cosign image signing, SLSA framework, Wiz, Prisma Cloud, Orca, Lacework
Languages & Automation:	Python, Go, Bash, Rego, Terraform, Kubernetes Operator SDK, GitHub Actions composite actions, Helm

EDUCATION

California Polytechnic State University, San Luis Obispo B.S. in Computer Science San Luis Obispo, CA • Sep 2014 - Jun 2018

WORK EXPERIENCE

Sysdig Senior DevSecOps Engineer

San Francisco, CA • Aug 2022 - Present

- Owned the DevSecOps program across the container-security product engineering org supporting **540+ engineers**, embedding controls across **CI/CD scanning gates**, **IaC** and **container security**, and **supply-chain controls** across **280+ CI/CD pipelines**.
- Ran the AppSec scanning program, integrating **Semgrep** SAST rules per repo type, **Snyk** SCA with license-policy gates, and **OWASP ZAP** staging-environment DAST, triaging **6,200+** findings per quarter and cutting false-positive rate from **41%** down to **8%**.
- Embedded IaC scanning gates with **Checkov** on Terraform and Helm in PR-blocking mode, plus **tfsec** for module-level guardrails and Kubernetes manifest linting in CI, across **190+** IaC repos and cutting critical misconfigurations by **78%**.
- Drove container and Kubernetes hardening with **Trivy** image scanning at build and runtime, **OPA Gatekeeper** admission policies, and Falco runtime detection for privileged exec, protecting **1,400** production images across **12 EKS and GKE** production clusters.
- Owned secrets management and detection with **HashiCorp Vault** for **dynamic AWS credentials**, **GitGuardian** pre-receive hooks across all repos, and break-glass rotation plus access-review workflows, blocking **380+** secrets-leak attempts in CI per **quarterly** cycle.
- Built policy-as-code guardrails on **OPA** with Rego policies on Terraform plan output, **Kyverno** cluster policies on Kubernetes admission, and **Conftest** gates on Helm charts before deploy, blocking **97.2%** of non-compliant deploys across the engineering org.
- Stood up **SLSA-aligned** supply-chain controls with Syft-generated SBOMs in **CycloneDX** format, **Sigstore Cosign** image signing and verification, and dependency-provenance attestations at build time, signing **100%** of production images and Helm charts and achieving **SLSA Build Level 3** on the core image-build pipelines.

PagerDuty DevSecOps Engineer

San Francisco, CA • Jun 2019 - Jul 2022

- Built the cloud-security automation program across **84 AWS** accounts, with **Wiz** CNAPP findings auto-tagged to repo owners, Lambda remediations for tagging and encryption drift, and AWS SCP guardrails for new account onboarding, cutting cloud-misconfig MTTR from **11 days** to **2 days**.
- Built the developer-enablement and security-champions program with paved-road golden pipelines for new services, secure-coding workshops aligned to **OWASP Top 10**, and quarterly security-champions retros, onboarding **22** champions across **9** product teams and lifting new-service adoption of the secure-default pipeline from **38%** to **92%**.
- Ran the vulnerability-metrics and continuous-improvement program, aggregating findings across SAST, SCA, IaC, and container scanners, prioritizing by **exploitability** and asset criticality, and tuning rules monthly to retire noise; cut mean time to remediate critical findings from **21 days** to **4 days** and held escape rate to prod **under 0.7%** across **18 months**.
- Worked closely with **Engineering, SRE, Platform, and Security** teams to coordinate **quarterly DevSecOps RFCs**, **threat-model** facilitation, and **incident postmortem** actions, authoring **14 DevSecOps playbooks** that shaped the team's standard playbook and mentoring **4 junior DevSecOps engineers** through their first paved-road launches.